Advanced Learning University

Data Protection and Privacy Regulations

Document ID:	ALU-DP-2026-001
Effective Date:	May 06, 2026
Version:	1.0
Policy Owner:	Data Protection Officer (DPO)

1. Purpose

Advanced Learning University (ALU) is committed to maintaining the highest standards of data privacy and security. This regulation establishes the mandatory principles, rules, and controls governing the collection, use, storage, and protection of personal and institutional data within the university environment. The primary objectives of this regulation are to:

- Ensure that all data practices are conducted in a lawful, fair, and transparent manner.
- Protect the fundamental rights and privacy of students, staff, researchers, and stakeholders.
- Minimize legal, financial, and operational risks associated with data breaches or non-compliance.
- Enable the responsible and ethical use of data to support the university's academic and research mission.

2. Scope

These regulations apply to all faculties, administrative departments, research centers, staff members, students, and authorized third parties acting on behalf of the university. The scope encompasses all information systems, physical records, and data sets managed by the university, including but not limited to:

- Student academic, financial, and health records.
- Employee personnel files and payroll information.
- Research data involving human subjects.
- Stakeholder and alumni contact information.
- Institutional strategic and operational data.

3. Definitions

Personal Data: Any information relating to an identified or identifiable natural person (Data Subject).

Sensitive Data: Special categories of data that require higher protection, including health information, financial records, biometric data, and ethnicity.

Data Subject: Any individual whose personal data is collected, held, or processed by the university.

Data Controller: The university entity that determines the purposes and means of processing personal data.

Data Processor: A natural or legal person, public authority, or agency which processes personal data on behalf of the controller.

4. Core Principles

All data processing activities at ALU must adhere to the following core principles:

Lawfulness & Fairness: Data must be collected legally and used in a way that is fair and not misleading.

Purpose Limitation: Data must be collected for specified, explicit, and legitimate purposes and not further processed in a manner incompatible with those purposes.

Data Minimization: Personal data shall be adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed.

Accuracy: Data must be kept accurate and, where necessary, kept up to date; inaccurate data must be erased or rectified without delay.

Storage Limitation: Data should be kept in a form which permits identification of data subjects for no longer than is necessary.

Integrity & Confidentiality: Data must be processed in a manner that ensures appropriate security, including protection against unauthorized or unlawful processing.

5. Legal Basis for Processing

The university must identify a valid legal basis before processing personal data. These include:

- Consent: The individual has given clear consent for the university to process their personal data for a specific purpose.
- Contractual Necessity: The processing is necessary for a contract the university has with the individual.
- Legal Obligation: The processing is necessary for the university to comply with the law.

- Legitimate Interest: The processing is necessary for the university's legitimate interests or the interests of a third party, unless there is a good reason to protect the individual's personal data.

6. Consent Requirements

Where processing is based on consent, the university must be able to demonstrate that the individual has consented. Consent must be freely given, specific, informed, and an unambiguous indication of the subject's wishes. Individuals have the right to withdraw their consent at any time without prejudice.

7. Data Collection Rules

Transparency is mandatory. When collecting data, the university must provide individuals with information regarding the purpose of collection and how the data will be used. The following are strictly prohibited:

- Excessive data collection beyond the stated purpose.
- Misuse of data for secondary purposes without a legal basis.
- Unauthorized sharing of personal data with internal or external parties.
- Processing of Sensitive Data without additional security safeguards and explicit legal justification.

8. Data Subject Rights

The university recognizes and protects the following rights of data subjects:

- Right to Access: To obtain a copy of their personal data held by the university.
- Right to Rectification: To have inaccurate or incomplete data corrected.
- Right to Erasure: To request the deletion of data where there is no compelling reason for its continued processing.
- Right to Restriction: To block or suppress the processing of personal data.
- Right to Data Portability: To obtain and reuse their personal data for their own purposes across different services.
- Right to Complain: To lodge a complaint with the Data Protection Officer or relevant regulatory authority.

9. Data Security

The university shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk. These measures include:

- Encryption of data at rest and in transit.
- Strict access control and multi-factor authentication for sensitive systems.

- Regular security awareness training for all staff and students.
- Periodic security audits and vulnerability assessments.
- Establishment of a robust Data Incident Response Plan.

10. Data Retention and Disposal

Personal data shall not be kept for longer than is necessary for the purposes for which it was collected. Each department must maintain a Data Retention Schedule defining specific periods. Upon expiry of the retention period, data must be securely deleted or anonymized for historical or statistical research.

11. Third-Party Data Sharing

Sharing data with third parties (e.g., software vendors, partner institutions) is permitted only when:

- A formal Data Processing Agreement is in place.
- The third party demonstrates compliance with these regulations.
- Access is limited to the minimum data required for the service.
- Unauthorized sharing is strictly prohibited and subject to penalties.

12. Governance

The University Data Protection Officer (DPO) is responsible for overseeing compliance with this regulation. Individual units and departments are responsible for the day-to-day management of data within their jurisdiction. The Internal Audit department will conduct regular reviews to ensure adherence to these standards.

13. Risk Management

All new projects or systems involving personal data must undergo a Data Protection Impact Assessment (DPIA). Risks must be assessed based on the impact on individuals/institutions and the likelihood of occurrence. High-risk activities must have documented mitigation strategies.

Impact Level	Score	Operational Impact	Legal & Compliance Impact	Financial Impact	Reputational Impact	Data Privacy / Security Impact	Example University Scenario
Very Low	1	Minor inconvenience with no service disruption	No regulatory issue	Negligible cost	No public awareness	No exposure of sensitive data	Temporary LMS slowdown for <10 minutes
Low	2	Small disruption affecting one unit or class	Minor policy deviation	Small remediation cost	Limited internal concern	Exposure of low-sensitivity	Wrong email sent internally without

Impact Level	Score	Operational Impact	Legal & Compliance Impact	Financial Impact	Reputational Impact	Data Privacy / Security Impact	Example University Scenario
						data to limited users	sensitive attachment
Moderate	3	Operational disruption affecting multiple departments	Potential internal compliance finding	Moderate recovery/remediation cost	Negative feedback from students/staff	Limited exposure of personal data	Unauthorized access to attendance records
High	4	Significant disruption of academic or administrative operations	Violation of university policy or possible UU PDP / UU ITE non-compliance	Major financial impact or penalty risk	Public criticism or media attention	Exposure of sensitive personal data	Lecturer shares student grades publicly
Critical	5	Severe institutional disruption or system shutdown	Major legal/regulatory violation with investigation risk	Severe financial loss, lawsuit, or sanction	Major reputation crisis affecting university trust	Large-scale breach of sensitive data	Student database leaked publicly or ransomware attack

Likelihood Level	Score	Probability Description	Control Effectiveness	Frequency Indicator	Typical Warning Signs	Example University Scenario
Rare	1	Highly unlikely to occur under normal conditions	Strong controls implemented and monitored	May occur once in several years	No prior incidents, strong governance, regular audit	Encrypted academic records accessed only through MFA
Unlikely	2	Possible but not expected during normal operations	Controls generally effective with minor weaknesses	Occasional isolated incident	Minor policy deviations or low exposure	Lecturer accidentally sends internal memo to wrong staff
Possible	3	Could reasonably occur during operations	Controls partially implemented or inconsistently applied	Happens occasionally	Weak monitoring, inconsistent awareness	Shared use of staff accounts in one department
Likely	4	Expected to occur repeatedly without intervention	Weak controls or policy enforcement	Repeated incidents observed	Frequent violations, poor compliance culture	Student data regularly shared through personal messaging apps
Almost Certain	5	Very likely or already occurring continuously	Controls absent or ineffective	Frequent or ongoing occurrence	No governance, repeated incidents, unmanaged systems	Passwords stored openly or public access to sensitive data

RISK MATRIX (IMPACT x LIKELIHOOD)

University Risk Assessment – Based on UU PDP (No. 27/2022) & UU ITE (No. 11/2008)

IMPACT How severe are the consequences if the risk occurs?	LIKELIHOOD – How likely is the risk to occur? 1 RARE Highly unlikely	2 UNLIKELY Not expected	3 POSSIBLE Could occur	4 LIKELY Will probably occur	5 ALMOST CERTAIN Expected to occur frequently
5 CRITICAL Severe institutional impact	5 MEDIUM	10 HIGH	15 HIGH	20 VERY HIGH	25 CRITICAL
4 HIGH Major impact	4 LOW	8 MEDIUM	12 HIGH	16 VERY HIGH	20 VERY HIGH
3 MODERATE Moderate impact	3 LOW	6 MEDIUM	9 MEDIUM	12 HIGH	15 HIGH
2 LOW Minor impact	2 LOW	4 LOW	6 MEDIUM	8 MEDIUM	10 HIGH
1 VERY LOW Insignificant impact	1 LOW	2 LOW	3 LOW	4 LOW	5 MEDIUM

RISK SCORE & LEVEL LEGEND

20 – 25	CRITICAL	Immediate action required Executive escalation
16 – 19	VERY HIGH	Urgent mitigation required Monitor closely
10 – 15	HIGH	Manage and reduce risk Action plan required
6 – 9	MEDIUM	Monitor and improve controls Preventive actions
1 – 5	LOW	Acceptable risk Monitor periodically

HOW TO USE THIS MATRIX

1. Identify the risk scenario
2. Assess the Impact (1-5) based on potential consequences
3. Assess the Likelihood (1-5) based on probability of occurrence
4. Find the intersection cell to get the Risk Score
5. Determine Risk Level and required action based on legend

REGULATORY CONTEXT

UU PDP (No. 27/2022)
- Lawful and fair data processing
- Data subject rights protection
- Data security and breach obligations
- Administrative sanctions up to 2% of annual revenue

UU ITE (No. 11/2008)
- Electronic system security
- Protection of electronic data
- Unauthorized access prohibited
- Criminal & civil penalties

EXAMPLE INTERPRETATION

If a risk has **Impact** = 4 (High) and **Likelihood** = 3 (Possible)
Risk Score = 12 → **Risk Level** = HIGH
Action: Manage and reduce risk, action plan required.

Example Scenario:
Student personal data shared via personal email
(Impact: High, Likelihood: Possible → Score: 12)

14. Compliance

Failure to comply with these regulations may result in disciplinary action, up to and including termination of employment or expulsion from the university. Legal action may also be pursued in cases of severe or criminal negligence.

15. Training

Data protection training is mandatory for all employees. Awareness programs will be conducted annually to ensure that the university community remains informed about their responsibilities and emerging threats.

16. Review

This regulation will be reviewed annually by the Office of the DPO or more frequently in response to changes in legislation or university operational requirements.